SECCIÓN 6.6

Comunicación operativa durante un posible incidente

Temas de esta sección:

- Por qué comunicar bien es tan importante como analizar bien
- Separar hechos, hipótesis y recomendaciones en toda comunicación
- Cómo evitar alarmismo y cómo evitar minimización
- Tipos de mensajes: escalamiento técnico, pedido de validación, update, recomendación
- Cómo comunicar a negocio sin exceso de jerga
- Ejercicios: mejorar mensajes, pedidos de validación y comunicación a negocio

6.6 | Por qué comunicar bien es tan importante como analizar bien

Un análisis correcto comunicado incorrectamente puede generar el mismo daño que un análisis incorrecto.

Mensaje alarmista sin evidencia	→	Genera pánico, moviliza recursos innecesarios, puede causar acciones precipitadas que destruyen evidencia
Mensaje minimizador con evidencia real	→	Genera falsa calma, retrasa la respuesta, permite que la amenaza escale sin respuesta adecuada
Escalamiento sin contexto suficiente	→	El receptor no puede actuar. Empieza de cero. Demora la respuesta. Genera frustración entre equipos
Lenguaje técnico excesivo a negocio	→	El decisor no puede tomar la decisión correcta porque no entiende el impacto en términos operativos
Lenguaje vago o ambiguo ('algo raro')	→	No permite priorizar. No define quién actúa. No establece urgencia real. Genera confusión operativa

Una comunicación clara distingue tres niveles. Mezclarlos genera confusión y puede llevar a decisiones incorrectas.

HECHOS OBSERVADOS	Lo que muestran los logs, alertas y eventos concretos.	*Ejemplo: WINWORD.EXE ejecutó powershell.exe con -enc. Se creó update.exe en C:\Users\Public\. Hubo conexión HTTPS hacia billing-check-update.net.*
HIPÓTESIS	Interpretación posible basada en los hechos, sin confirmar.	*Ejemplo: La secuencia es compatible con posible ejecución inicial mediante documento y descarga de payload.*
RECOMENDACIÓN	Acción propuesta basada en la evidencia y la hipótesis.	*Ejemplo: Se recomienda escalar a IR y evaluar aislamiento del endpoint afectado.*

No mezclar estos tres niveles evita confirmar cosas que todavía no están demostradas.

6.6 | Cómo evitar alarmismo y cómo evitar minimización

Dos errores opuestos, igualmente dañinos:

ALARMISMO

```
Urgente, hay ransomware en el servidor de pagos. ¡Hay que
apagar todo ahora!

Contexto real:
- 3,400 archivos renombrados en 8 min
- vssadmin delete shadows
- svc_backup (¿backup job activo?)
- Sin ransom note todavía
```

Problemas:
✘ Confirma ransomware sin evidencia directa
✘ Pide apagar sin preservar ni coordinar
✘ Genera pánico y puede destruir evidencia
✘ No incluye contexto que podría aclarar

Se observa actividad compatible con posible ransomware en FILE-SRV-02. 3,400 archivos modificados y vssadmin delete shadows ejecutado. Existe backup job en la misma ventana — requiere validación. Por impacto potencial, se recomienda escalamiento urgente.

MINIMIZACIÓN

```
PowerShell detectado. Sin actividad adicional relevante.
Cerrado como falso positivo.

Contexto real:
- WINWORD.EXE → PS -enc
- update.exe en C:\Public\
- Tarea programada creada
- Conexión periódica externa
```

Problemas:
✘ Ignora la cadena de actividad posterior
✘ Cierra sin validar contexto completo
✘ 'Sin actividad adicional' no fue verificado
✘ La cadena indica ejecución inicial probable

Se observó WINWORD.EXE→PS -enc en FIN-LAP-022. Hay actividad posterior: creación de update.exe, tarea programada y conexión periódica a dominio externo. La secuencia no puede cerrarse sin escalamiento y revisión de alcance.

6.6 | Tipos de mensajes operativos: cuatro formatos

Cada tipo de mensaje tiene un propósito distinto y un destinatario distinto:

ESCALAMIENTO TÉCNICO **→ Tier 2 / IR / Equipo especializado**	Incluir: Activo · Evidencia principal · Riesgo · Acción recomendada	*Ej: Se escala FIN-LAP-022. WINWORD→PS -enc, update.exe en Public, conexión a dominio externo. Allowed. Sin ticket. → Análisis del archivo y posible aislamiento.*
PEDIDO DE VALIDACIÓN **→ IT / Identidad / Usuario / Negocio**	Incluir: Qué ocurrió · Pregunta concreta · Urgencia	*Ej: ¿legal.romero tenía autorización para descargar ~1,200 archivos SharePoint entre 10:05-10:30 desde un dispositivo nuevo?*
UPDATE DE ESTADO **→ IR / Management / Turno siguiente**	Incluir: Qué cambió · Acción tomada · Pendiente · Próximo paso	*Ej: Update 12:40: 2 hosts adicionales con mismo hash. IR autorizó aislamiento de 3 endpoints. Pendiente: correo origen y otros destinatarios.*
COMUNICACIÓN A NEGOCIO **→ Dueño del sistema / Management**	Incluir: Sin jerga técnica · Sin alarmismo · Qué servicio · Qué decisión se necesita	*Ej: Estamos revisando actividad sospechosa en el portal de pagos. Los equipos técnicos evalúan opciones de contención. ¿Qué impacto tendría aplicar una restricción temporal?*

El área de negocio necesita tomar decisiones, no entender técnica. La comunicación debe ser clara, sin alarmismo y orientada a la acción:

Mensaje técnico a negocio	Mensaje claro y accionable
`"Detectamos un webshell en w3wp.exe que ejecutó cmd.exe y whoami en WEB-PAY-01 vía WAF bypass con Command Injection en HTTP 200."`	`"Detectamos actividad sospechosa en el portal de pagos. Estamos evaluando las opciones de contención junto con los equipos técnicos y de infraestructura."`
Jerga que no aporta contexto operativo	Dice qué servicio está involucrado
No explica qué servicio está afectado	No usa jerga técnica innecesaria
No dice qué decisión se necesita	Muestra que hay coordinación activa
No da una recomendación clara	Abre el camino para pedir decisión

Estructura básica para comunicar a negocio:

¿Qué servicio o área está involucrada?	*Portal de pagos, sistema de clientes, área de Finanzas*	**¿Qué estamos haciendo?**	*Investigando y coordinando con equipos técnicos*
¿Qué necesitamos de negocio?	*¿Podemos restringir X? ¿Cuál es el impacto operativo?*	**¿Cuándo damos la próxima actualización?**	*En 30 minutos o cuando haya un cambio relevante*

6.6 | Ejercicio: mejorar tres mensajes

Mejorar estos mensajes aplicando hechos, hipótesis, certeza y proporcionalidad:

RANSOMWARE POSIBLE	FALSO POSITIVO VALIDADO	CUENTA COMPROMETIDA
✘ Original: 'Urgente, hay ransomware en FILE-SRV-02. Hagan algo rápido.'	✘ Original: 'PowerShell sospechoso. Revisar urgente.'	✘ Original: 'Hay algo raro con la cuenta de una persona del área legal.'
Mejorado: 'Se observa actividad compatible con posible ransomware en FILE-SRV-02: 3,400 archivos modificados en 8 min y vssadmin delete shadows por svc_backup. Existe backup job programado — debe validarse. Se recomienda escalamiento urgente a IR e infraestructura. Nivel: compatible con posible ransomware. No confirmado aún.'	Mejorado: 'Se observó PowerShell con ExecutionPolicy Bypass en IT-ADM-02 (soporte.admin). Se validó que coincide con el despliegue del agente EDR del cambio CHG-2026-3301, con ventana aprobada 22:00-23:30. Host en alcance. Sin actividad adicional sospechosa. Se cierra como actividad autorizada.'	Mejorado: 'Se solicita revisión prioritaria de legal.romero por posible compromiso. Login desde dispositivo desconocido, MFA ok, seguido de regla de reenvío externa, OAuth app con Read Mail/Files y descarga de 1,200 archivos SharePoint. Solicitar validación de sesiones, tokens y OAuth. Cuenta con acceso a info legal sensible.'